

INCIDENT RESPONSE PLAN

Elite Healthcare

HIPAA Data Breach Scenario

Prepared by: JVK Enterprise Holdings Solutions LLC | SEP 2026

1. PURPOSE AND SCOPE

This Incident Response Plan (IRP) defines the procedures Elite Healthcare will follow when a security incident occurs, with a specific focus on HIPAA-covered data breaches involving Protected Health Information (PHI). This plan applies to all employees, contractors, and third-party vendors who access Elite Healthcare systems or patient data.

2. Incident Response Team

Role	Responsibilities	Contact
Incident Response Lead	Oversee all response activities	Clinic Administrator
IT Security Officer	Technical investigation and containment	IT department
Privacy Officer	HIPAA breach assessment and notification	Compliance Team
Legal Counsel	Legal guidance and regulatory reporting	External Legal Team
Community Lead	Internal and external communications	Office Manager

3. Incident Scenario

Scenario: HIPAA Data Breach via Phishing Attack

A staff member receives a phishing email impersonating an internal IT notification. The employee clicks a malicious link and unknowingly provides their login credentials. The attacker uses these credentials to access the Electronic Health Record (EHR) system and exfiltrates PHI for approximately 450 patients before detection. This scenario triggers HIPAA breach-notification requirements.

Phase 1: Preparation

Actions taken before an incident to ensure readiness.

- Develop and distribute this Incident Response Plan to all staff.
- Conduct annual security awareness training focused on phishing and social engineering.
- Implement Multi-Factor Authentication (MFA) on all systems accessing PHI.
- Maintain an up-to-date asset inventory of all systems that store or process PHI.
- Establish relationships with external forensic and legal partners.
- Test backup and recovery procedures quarterly.

Phase 2: Identification

Detecting and confirming a security incident.

- Monitor system logs and EHR access reports for unusual login activity.
- Investigate alerts from endpoint protection, SIEM, or email-security tools.
- Interview the affected employee to assess the scope of credential compromise.
- Confirm whether PHI was accessed, viewed, or exfiltrated (HIPAA applicability).
- Document the time, date, and nature of the incident immediately.
- Assign a severity level (Low, Medium, High, Critical).

Phase 3 Containment

Limiting impact and preventing further unauthorized access.

- Immediately deactivate the compromised user account.
- Enforce a password reset for all accounts with similar access levels.
- Isolate affected workstations from the network if malware is suspected.
- Preserve relevant logs and evidence for forensic analysis.
- Notify the Incident Response Lead and Privacy Officer within one hour of confirmation.

Phase 4. Eradication

Removing the root cause and eliminating malicious activity.

- Remove any malware or unauthorized software installed during the breach.
- Patch vulnerabilities or misconfigurations that were exploited in the attack.
- Revoke unauthorized access tokens or active sessions.
- Audit all user accounts for potential additional compromise.
- Verify the EHR system's integrity and confirm that no data has been altered or deleted.
- Conduct a root-cause analysis to determine how the phishing attempt succeeded.

Phase 5: Recovery

Restoring normal operations safely.

- Restore affected systems from clean backups if necessary.
- Monitor systems for indicators of re-infection or ongoing unauthorized access.
- Validate that all services, applications, and user accounts are functioning normally.
- Reintroduce systems to the network in a controlled manner.

Phase 6 Lessons Learned

Improving long-term readiness.

- Conduct a post-incident review meeting within two weeks of resolution.
- Document what worked well and what gaps were identified.
- Update this Incident Response Plan based on findings.
- Provide targeted refresher training for staff involved in the incident.
- Report findings to leadership and update the organizational risk register.
- Track all corrective actions with assigned owners and due dates.
-

5. HIPAA Notification Requirements

Notification Type	Requirement	Deadline
Individual Notification	Written notice to all affected patients	Within 60 days of discovery
HHS Notification (500+)	Report to the HHS office for civil rights	Within 60 days of discovery
HHS Notification (<500)	Log and report to HHS annually	Within 60 days of the calendar year

Media Notification	Notice to prominent media outlets in the state	Within 60 days if 500+ and one state
--------------------	--	--------------------------------------

6. Plan Maintenance

This Incident Response Plan must be reviewed and updated annually, after any significant security incident, or when substantial changes occur to Elite Healthcare’s systems or operations. All updates must be approved by the Incident Response Lead and Privacy Officer before distribution.